



INTERNSHIELD

LEARN • PRACTICE • DEFEND • SECURE • INNOVATE

CLOUD COMPUTING & SECURITY

LAB 02

S3 BUCKET

SECURITY TESTING / EXPLOITATION

Assess and exploit S3 bucket misconfigurations to understand access controls and data exposure risks.



DISCOVER

Identify exposed
S3 buckets



ASSESS

Test bucket
access controls



EXPLOIT

Extract and analyze
exposed data



MITIGATE

Understand risks and
secure configurations



PROTECT

Strengthen cloud
security posture

PRACTICAL LABORATORY MANUAL

HANDS-ON CLOUD SECURITY EXERCISES



AUTHORIZED TRAINING ENVIRONMENT

This lab is designed for educational purposes only.
Perform all exercises only in authorized lab
environments and with explicit permission.



LAB INFORMATION

FIELD	DETAIL
LAB	2
TITLE	Exploit S3 Buckets
PRIMARY PLATFORM	Amazon Web Services
SERVICE	Amazon S3
PRIMARY TOOL	AWS CLI
LAB TYPE	Authorized Cloud Security Assessment
FOCUS	S3 Bucket Access Control and Misconfiguration

LAB SCENARIO

S3 buckets are used by customers and end users to store text documents, PDFs, videos, images, and other data. To store this data, a user must create a bucket with a unique name.

This lab requires a sound working knowledge of enumerating S3 buckets. Using various techniques, an assessor can identify misconfigurations in bucket implementation and evaluate weaknesses in the storage security mechanism that could compromise data privacy. An open write session on a bucket could allow unauthorized modification of files, including application code, so this risk is demonstrated here using only harmless training objects. Locating a bucket's name and endpoint is also a key step in testing its security posture and identifying implementation vulnerabilities.

AUTHORIZED TRAINING ENVIRONMENT

This laboratory must be performed only against an instructor-provided S3 bucket specifically created for security training.

Never use:

- Production buckets
- Third-party buckets
- Personal production data
- Customer data
- Unauthorized public buckets

LAB OBJECTIVES

- Assess an intentionally open/misconfigured S3 training bucket using AWS CLI within an authorized training environment.

Learning Objectives

- Understand S3 bucket access controls.
- Identify excessive permissions.
- Assess object-level access.
- Understand the security impact of unauthorized write access.
- Understand the security impact of unauthorized delete access.
- Document findings.
- Recommend appropriate remediation.

TOOL OVERVIEW

AWS Command Line Interface (AWS CLI)

The AWS CLI is a unified command-line tool for managing AWS services. It allows authorized users to interact with AWS services from the command line and automate administrative and assessment tasks.

AWS CLI	AUTHENTICATION	AWS S3	BUCKET	OBJECTS	ACCESS CONTROL
---------	----------------	--------	--------	---------	----------------

CREDENTIAL SECURITY WARNING

This lab involves configuring AWS CLI authentication. Handle all credentials with care:

- Never place real credentials in screenshots.
- Never publish AWS credentials.
- Never commit credentials to GitHub or any repository.
- Never use production credentials.
- Use only instructor-provided temporary training credentials.
- Prefer short-lived credentials or an isolated training identity.
- Remove or disable temporary credentials after the exercise.

LAB ENVIRONMENT & PREREQUISITES

Requirement	Purpose
Parrot Security	Security-testing workstation
MATE Terminal	Command-line interface
AWS CLI	Authorized AWS management and assessment
Amazon S3	Storage service under assessment
Training Bucket	Intentionally configured laboratory resource
Temporary Credentials	Controlled, short-lived authentication

IMPORTANT

This laboratory demonstrates the security consequences of excessive S3 permissions.

All actions must be performed **ONLY** against the designated training bucket.

Do not reproduce this activity against a bucket belonging to another organization.

TASK 1

EXPLOIT OPEN S3 BUCKETS USING AWS CLI

Authorized S3 Bucket Security Assessment

OBJECTIVE

Assess the security impact of excessive permissions on an intentionally open S3 training bucket using AWS CLI. Students should observe how excessive permissions can allow object listing, controlled object upload, and controlled object deletion.



PRACTICAL PROCEDURE

STEP 01 LAUNCH THE TERMINAL

ACTION

In the Parrot Security machine, click the MATE Terminal icon in the menu to launch the terminal.

EXPECTED RESULT

A Terminal window opens.

SECURITY INSIGHT

Working from the dedicated security workstation keeps the assessment isolated from production systems.

STEP 02 OPEN A ROOT SHELL**ACTION**

In the Terminal window, obtain the administrative shell only as specified by the isolated training environment. The source workflow uses `sudo su` and press Enter.

```
sudo su
```

EXPECTED RESULT

The shell reflects root-level access.

SECURITY INSIGHT

Elevated privileges are only used within the controlled lab session, never on production infrastructure.

STEP 03 AUTHENTICATE TO THE TRAINING ENVIRONMENT**ACTION**

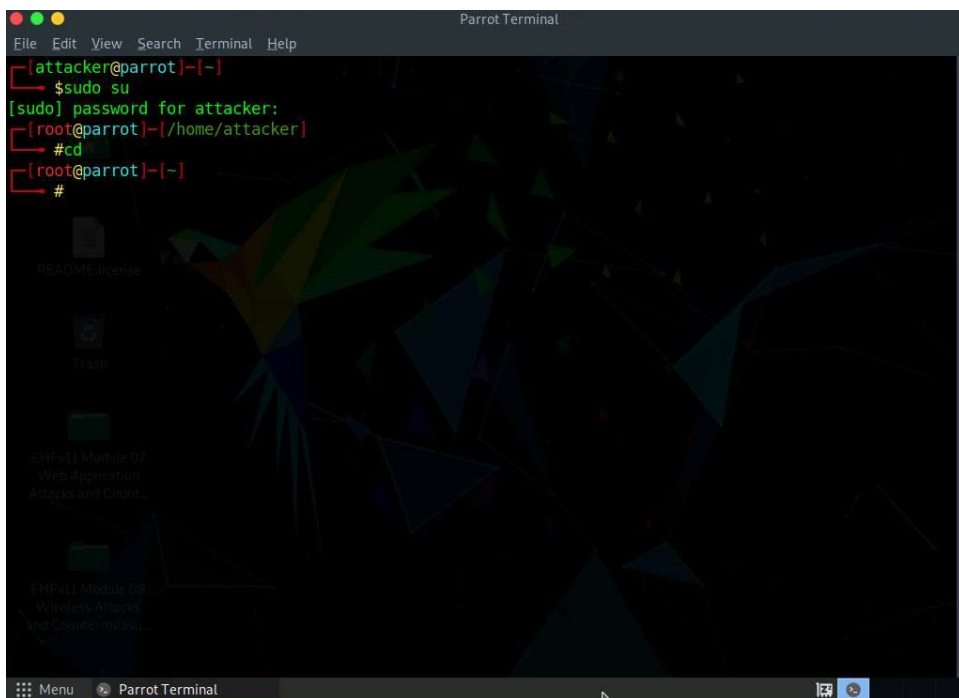
Authenticate using the instructor-provided training environment credentials. Do not display or record passwords.

EXPECTED RESULT

Root access is granted in the terminal.

SECURITY INSIGHT

Credentials for the lab environment should never be captured in documentation or screenshots.



```
Parrot Terminal
File Edit View Search Terminal Help
[attacker@parrot]~$ sudo su
[sudo] password for attacker:
[root@parrot]~/home/attacker# #cd
[root@parrot]~$ #
```

STEP 04 NAVIGATE TO THE WORKING DIRECTORY

ACTION

Navigate to the required working directory. The source workflow uses `cd` and press Enter.

```
cd
```

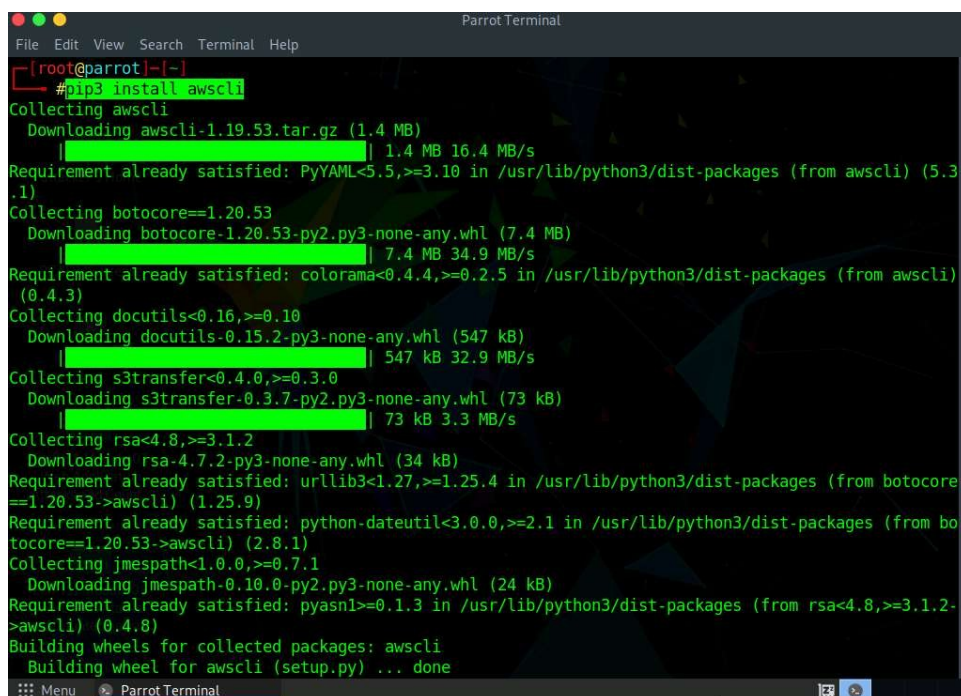
EXPECTED RESULT

The terminal prompt reflects the root directory.

SECURITY INSIGHT

Confirming the working directory avoids path errors during tool installation.

LAB 2 | S3 BUCKET SECURITY ASSESSMENT



```
root@parrot:~# pip3 install awscli
Collecting awscli
  Downloading awscli-1.19.53.tar.gz (1.4 MB)
    | 1.4 MB 16.4 MB/s
Requirement already satisfied: PyYAML<5.5,>=3.10 in /usr/lib/python3/dist-packages (from awscli) (5.3.1)
Collecting botocore==1.20.53
  Downloading botocore-1.20.53-py2.py3-none-any.whl (7.4 MB)
    | 7.4 MB 34.9 MB/s
Requirement already satisfied: colorama<0.4.4,>=0.2.5 in /usr/lib/python3/dist-packages (from awscli) (0.4.3)
Collecting docutils<0.16,>=0.10
  Downloading docutils-0.15.2-py3-none-any.whl (547 kB)
    | 547 kB 32.9 MB/s
Collecting s3transfer<0.4.0,>=0.3.0
  Downloading s3transfer-0.3.7-py2.py3-none-any.whl (73 kB)
    | 73 kB 3.3 MB/s
Collecting rsa<4.8,>=3.1.2
  Downloading rsa-4.7.2-py3-none-any.whl (34 kB)
Requirement already satisfied: urllib3<1.27,>=1.25.4 in /usr/lib/python3/dist-packages (from botocore==1.20.53->awscli) (1.25.9)
Requirement already satisfied: python-dateutil<3.0.0,>=2.1 in /usr/lib/python3/dist-packages (from botocore==1.20.53->awscli) (2.8.1)
Collecting jmespath<1.0.0,>=0.7.1
  Downloading jmespath-0.10.0-py2.py3-none-any.whl (24 kB)
Requirement already satisfied: pyasn1>=0.1.3 in /usr/lib/python3/dist-packages (from rsa<4.8,>=3.1.2->awscli) (0.4.8)
Building wheels for collected packages: awscli
  Building wheel for awscli (setup.py) ... done
```

STEP 05 INSTALL AWS CLI**ACTION**

Install AWS CLI only if it is not already installed in the training environment. The source workflow uses `pip3 install awscli` and press Enter.

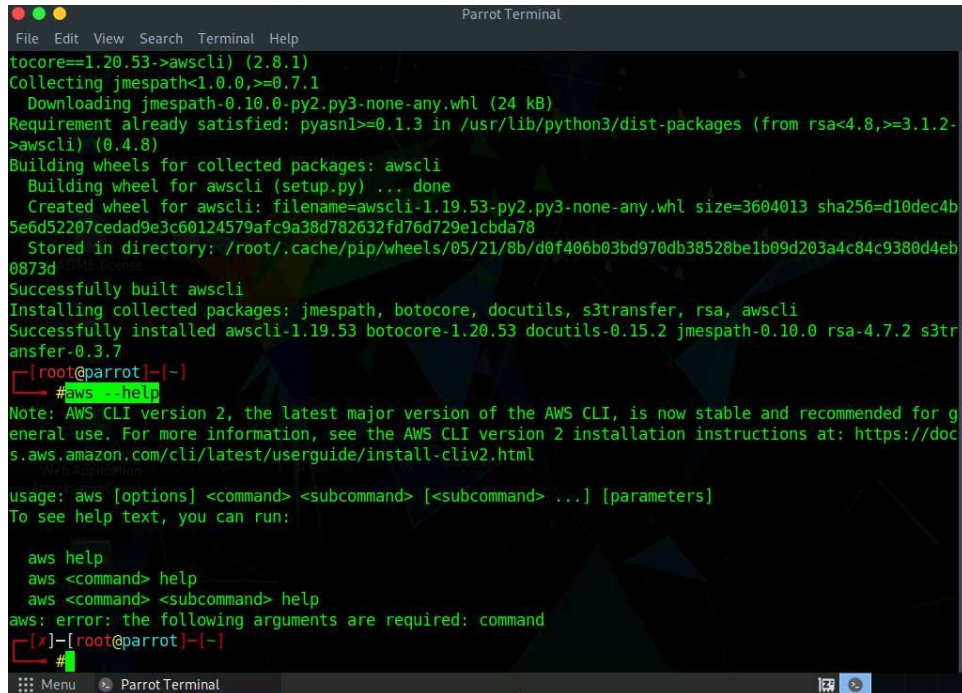
```
pip3 install awscli
```

EXPECTED RESULT

AWS CLI installs successfully, or is confirmed already present.

SECURITY INSIGHT

Using a known-good package source for CLI tooling reduces supply-chain risk during assessments.



STEP 06 VERIFY AWS CLI AVAILABILITY

ACTION

Verify AWS CLI availability by typing `aws --help` and pressing Enter. Harmless environment-specific warnings may appear and can be ignored.

```
aws --help
```

EXPECTED RESULT

AWS CLI help output is displayed, confirming the tool is available.

SECURITY INSIGHT

Verifying tool availability before configuration avoids troubleshooting confusion later in the exercise.

LAB 2 | S3 BUCKET SECURITY ASSESSMENT

```
Parrot Terminal
File Edit View Search Terminal Help
Collecting jmespath<1.0.0,>=0.7.1
  Downloading jmespath-0.10.0-py2.py3-none-any.whl (24 kB)
Requirement already satisfied: pyasn1>=0.1.3 in /usr/lib/python3/dist-packages (from rsa<4.8,>=3.1.2->awsccli) (0.4.8)
Building wheels for collected packages: awsccli
  Building wheel for awsccli (setup.py) ... done
  Created wheel for awsccli: filename=awsccli-1.19.53-py2.py3-none-any.whl size=3604013 sha256=d10dec4b5e6d52207cedad9e3c60124579afc9a38d782632fd76d729e1cbda78
  Stored in directory: /root/.cache/pip/wheels/05/21/8b/d0f406b03bd970db38528be1b09d203a4c84c9380d4eb00873d
Successfully built awsccli
Installing collected packages: jmespath, botocore, docutils, s3transfer, rsa, awsccli
Successfully installed awsccli-1.19.53 botocore-1.20.53 docutils-0.15.2 jmespath-0.10.0 rsa-4.7.2 s3transfer-0.3.7
[root@parrot]~#
#aws --help
Note: AWS CLI version 2, the latest major version of the AWS CLI, is now stable and recommended for general use. For more information, see the AWS CLI version 2 installation instructions at: https://docs.aws.amazon.com/cli/latest/userguide/install-cliv2.html
usage: aws [options] <command> [<subcommand> [<subcommand> ...] [parameters]]
To see help text, you can run:

    aws help
    aws <command> help
    aws <command> <subcommand> help
aws: error: the following arguments are required: command
[*]~[root@parrot]~#
#aws configure
AWS Access Key ID [None]:
```

STEP 07 BEGIN AWS CLI CONFIGURATION**ACTION**

Configure AWS CLI using the authorized temporary training credentials. Type `aws configure` and press Enter.

```
aws configure
```

EXPECTED RESULT

The AWS CLI configuration prompt sequence begins.

SECURITY INSIGHT

`aws configure` stores authentication details locally; only temporary, scoped credentials should ever be used here.

STEP 08 REVIEW THE CONFIGURATION FIELDS**ACTION**

The configuration sequence requests four fields: AWS Access Key ID, AWS Secret Access Key, Default Region, and Default Output Format. Never place actual credential values in the manual or in screenshots.

EXPECTED RESULT

The four configuration fields are understood before values are entered.

SECURITY INSIGHT

Each field maps to a distinct part of the authentication and API-behavior model, so understanding them reduces configuration errors.

STEP 09 ACCESS THE TRAINING ACCOUNT**ACTION**

Access the instructor-provided AWS training account through the approved browser.

EXPECTED RESULT

The approved browser is ready to reach the AWS console.

SECURITY INSIGHT

Using only the approved browser profile helps keep training-account activity separate from personal or production accounts.

STEP 10 OPEN THE APPROVED BROWSER**ACTION**

Open the approved browser from the Parrot Security desktop.

EXPECTED RESULT

The browser opens successfully.

SECURITY INSIGHT

A dedicated browser session for the lab reduces the chance of mixing training and personal credentials.

STEP 11 OPEN THE AWS CONSOLE

LAB 2 | S3 BUCKET SECURITY ASSESSMENT

ACTION

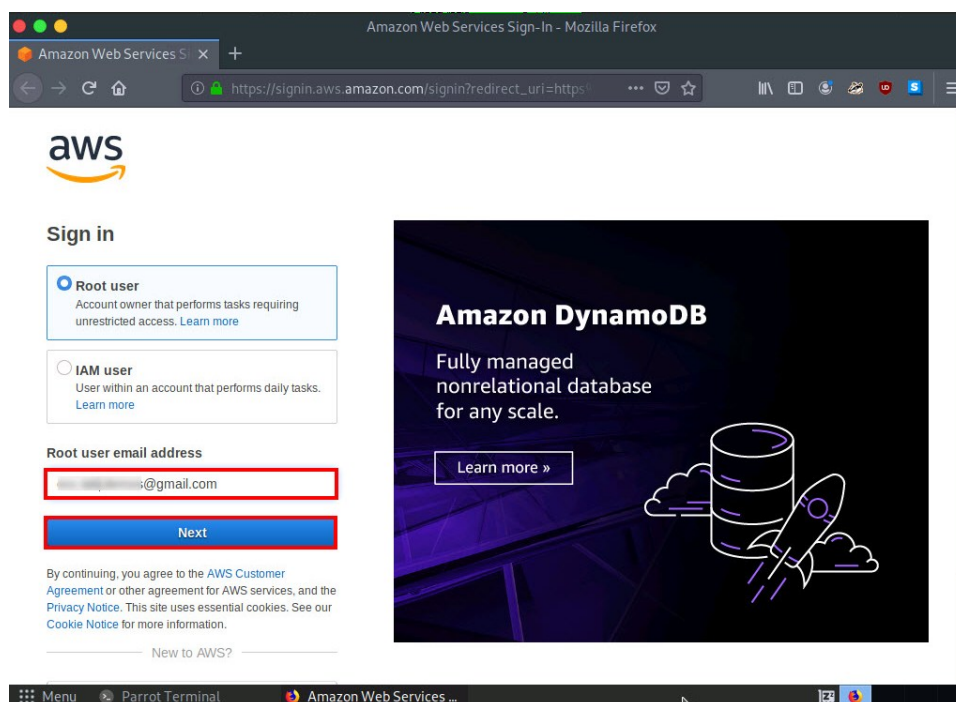
Open the AWS console using the official AWS website, signing in with the authorized training account.

EXPECTED RESULT

The AWS Sign-In page loads.

SECURITY INSIGHT

Always verify the console URL to avoid phishing pages that mimic the AWS sign-in flow.

**STEP 12 ENTER THE TRAINING ACCOUNT EMAIL**

ACTION

Enter the authorized training account email address in the sign-in field. Do not display the email address in screenshots.

EXPECTED RESULT

The sign-in flow proceeds to the next step.

SECURITY INSIGHT

Redacting account identifiers in documentation limits exposure if the material is shared or published.

STEP 13 COMPLETE SECURITY VERIFICATION**ACTION**

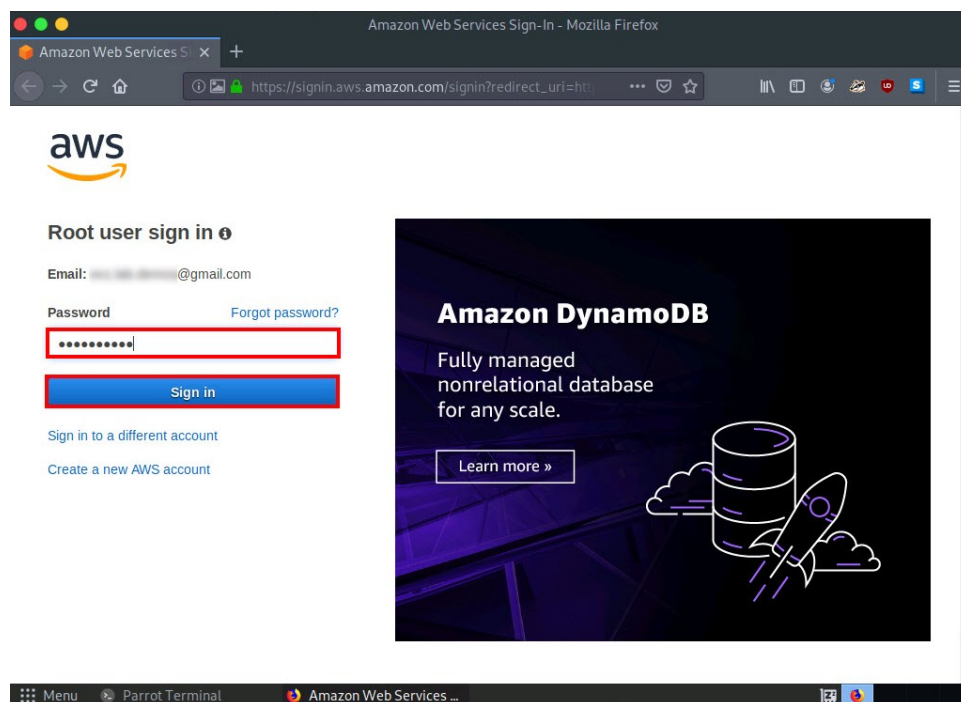
Complete the AWS security verification step if presented (for example, a captcha). Do not capture sensitive authentication information in screenshots.

EXPECTED RESULT

The security check is completed and sign-in proceeds.

SECURITY INSIGHT

Verification steps like captchas help prevent automated credential-stuffing attempts against the sign-in page.

**STEP 14 SIGN IN TO THE TRAINING ACCOUNT****ACTION**

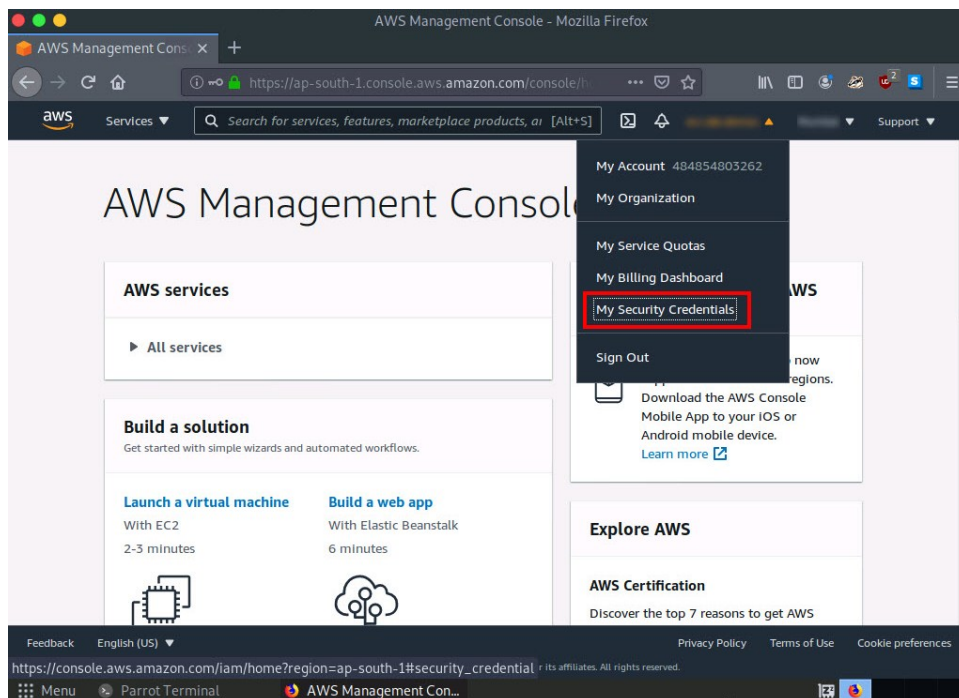
Authenticate to the authorized training account using the account password.

EXPECTED RESULT

Sign-in to the AWS console completes successfully.

SECURITY INSIGHT

Console sign-in should always occur over the official AWS domain using account credentials scoped to training use only.



STEP 15 NAVIGATE TO CREDENTIAL MANAGEMENT

ACTION

Navigate to the security-credential or approved temporary-access mechanism provided by the instructor. Do not create long-lived root-user access keys; prefer temporary training credentials.

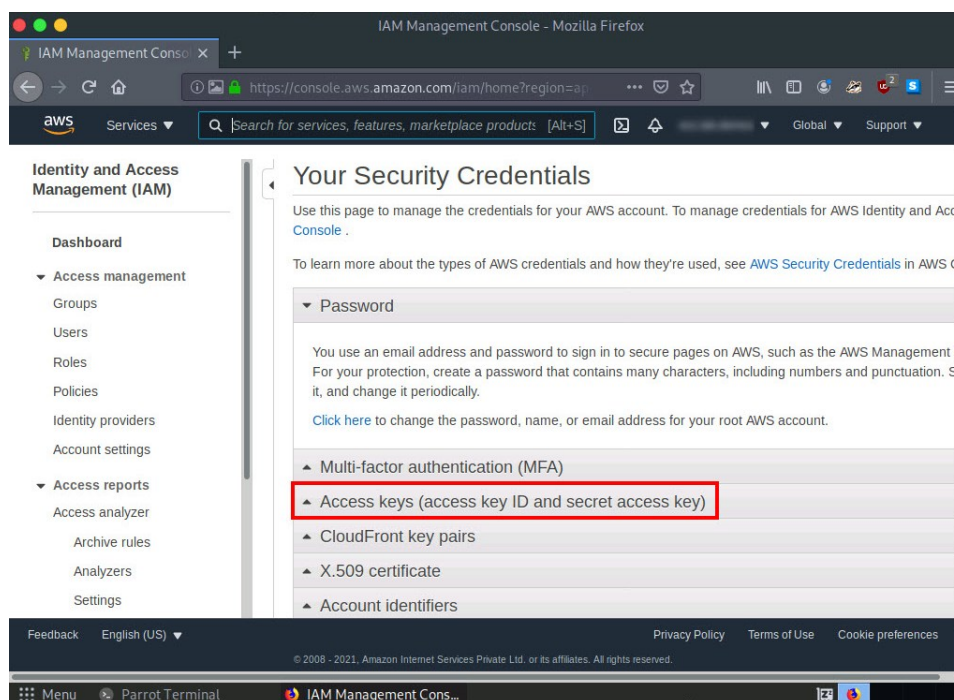
EXPECTED RESULT

The credential-management area of the console is displayed.

SECURITY INSIGHT

Long-lived root credentials carry significant risk if leaked; scoped, temporary credentials substantially reduce that exposure.

LAB 2 | S3 BUCKET SECURITY ASSESSMENT

**STEP 16 OPEN THE ACCESS-KEY MECHANISM****ACTION**

Open the approved access-key or temporary-credential mechanism in the console.

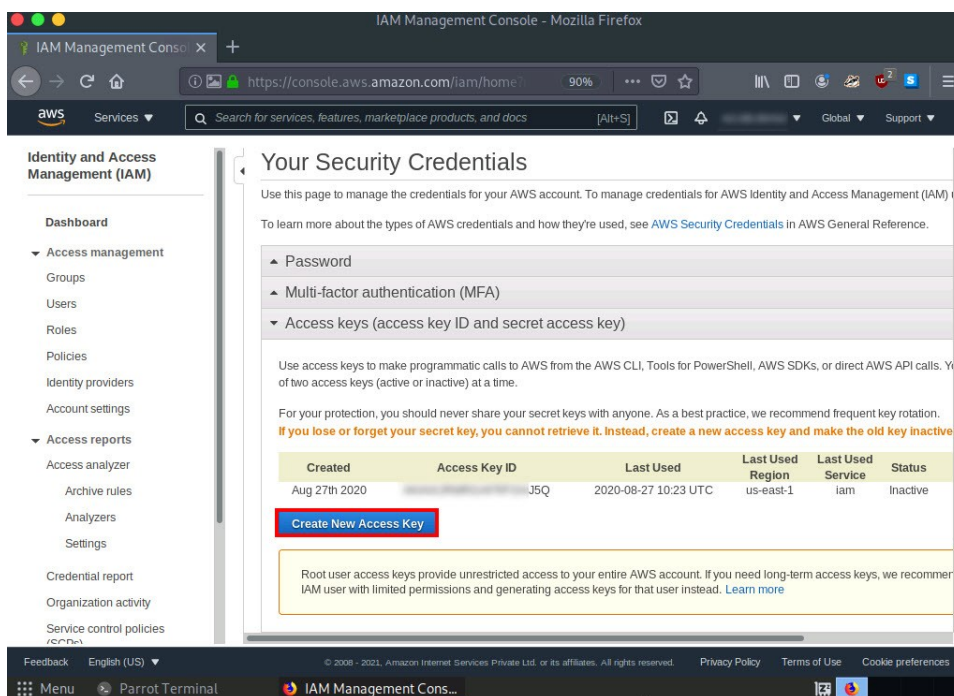
EXPECTED RESULT

The access-key management interface is displayed.

SECURITY INSIGHT

Reviewing this interface builds familiarity with how AWS issues and manages programmatic credentials.

LAB 2 | S3 BUCKET SECURITY ASSESSMENT

**STEP 17 OBTAIN TEMPORARY TRAINING CREDENTIALS****ACTION**

Generate or obtain the instructor-provided temporary training credentials if required by the lab environment.

EXPECTED RESULT

Temporary credentials are generated or confirmed available.

SECURITY INSIGHT

Temporary, scoped credentials limit the blast radius if a credential is accidentally exposed during the exercise.

STEP 18 CONFIRM CREDENTIAL AVAILABILITY**ACTION**

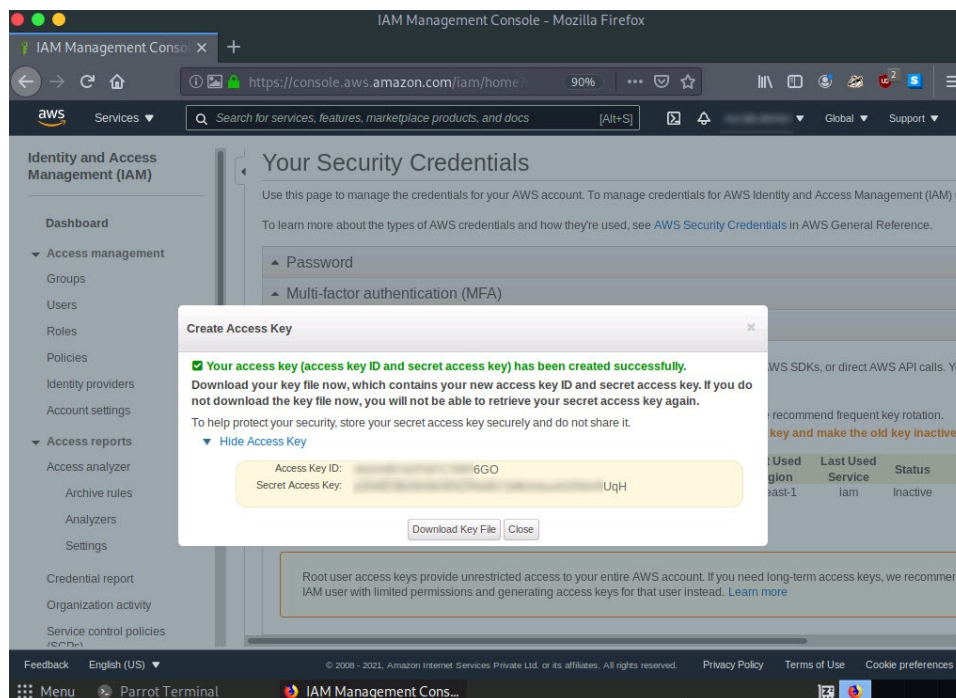
Confirm that the temporary credentials are available. Never place credential values into the document.

EXPECTED RESULT

Credentials are confirmed ready for use in the terminal.

SECURITY INSIGHT

Confirming availability before proceeding avoids interrupting the CLI configuration sequence midway.



STEP 19 RETURN TO THE AUTHORIZED WORKFLOW

ACTION

Copy or enter only the required training credential identifier into the authorized lab workflow. Never display secret values.

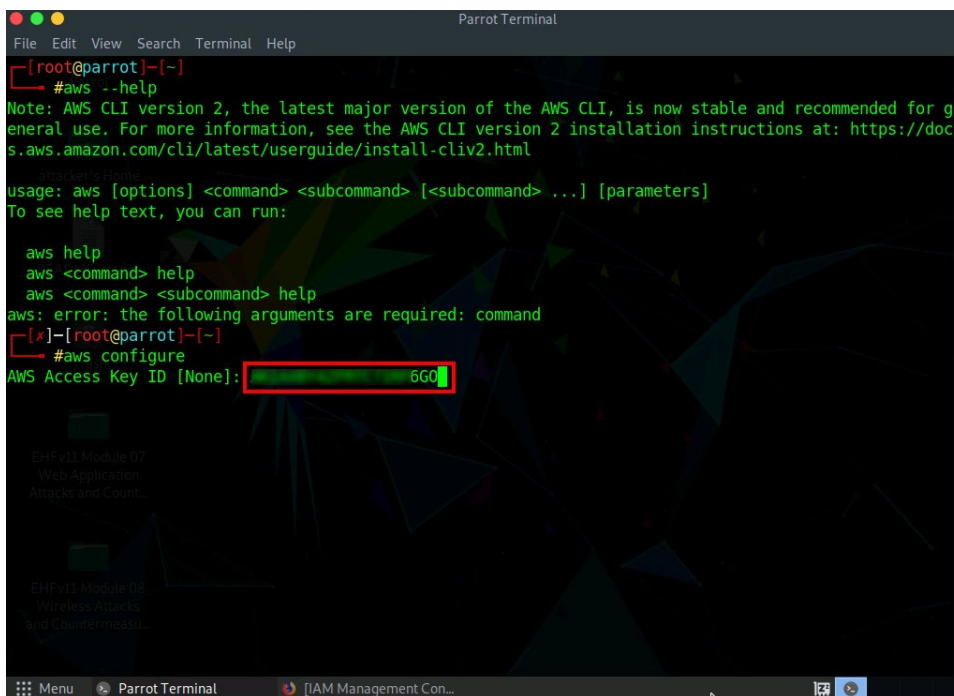
EXPECTED RESULT

The credential identifier is ready to be supplied to the terminal.

SECURITY INSIGHT

Separating the identifier from the secret value in handling reduces the chance of the secret being displayed inadvertently.

LAB 2 | S3 BUCKET SECURITY ASSESSMENT



```
[root@parrot]~# aws --help
Note: AWS CLI version 2, the latest major version of the AWS CLI, is now stable and recommended for general use. For more information, see the AWS CLI version 2 installation instructions at: https://docs.aws.amazon.com/cli/latest/userguide/install-cliv2.html

usage: aws [options] <command> [<subcommand> ...] [parameters]
To see help text, you can run:

    aws help
    aws <command> help
    aws <command> <subcommand> help
aws: error: the following arguments are required: command
[*]~[root@parrot]~# aws configure
AWS Access Key ID [None]: 6G0
```

STEP 20 SUPPLY THE ACCESS KEY ID**ACTION**

Configure the AWS CLI with the authorized training Access Key ID at the corresponding prompt.

EXPECTED RESULT

The AWS CLI accepts the Access Key ID and prompts for the secret.

SECURITY INSIGHT

The Access Key ID alone is not sufficient to authenticate; pairing it with a protected secret is what enforces access control.

STEP 21 SUPPLY THE SECRET ACCESS KEY**ACTION**

Enter the temporary secret credential through the secure terminal input mechanism. Do not save or publish the secret.

EXPECTED RESULT

The AWS CLI accepts the secret and proceeds to the next configuration prompt.

**SECURITY INSIGHT**

Terminal input for secrets is typically not echoed to the screen, which helps prevent shoulder-surfing exposure.

STEP 22 COMPLETE REMAINING PROMPTS**ACTION**

Complete the remaining AWS CLI configuration prompts securely.

EXPECTED RESULT

AWS CLI configuration proceeds to the region and output-format prompts.

SECURITY INSIGHT

Completing configuration deliberately, one prompt at a time, reduces the chance of entering values in the wrong field.

STEP 23 SET THE TRAINING REGION**ACTION**

Set the training region at the Default region name prompt. The source example uses eu-west-1; use the instructor-assigned training region if different.

```
eu-west-1
```

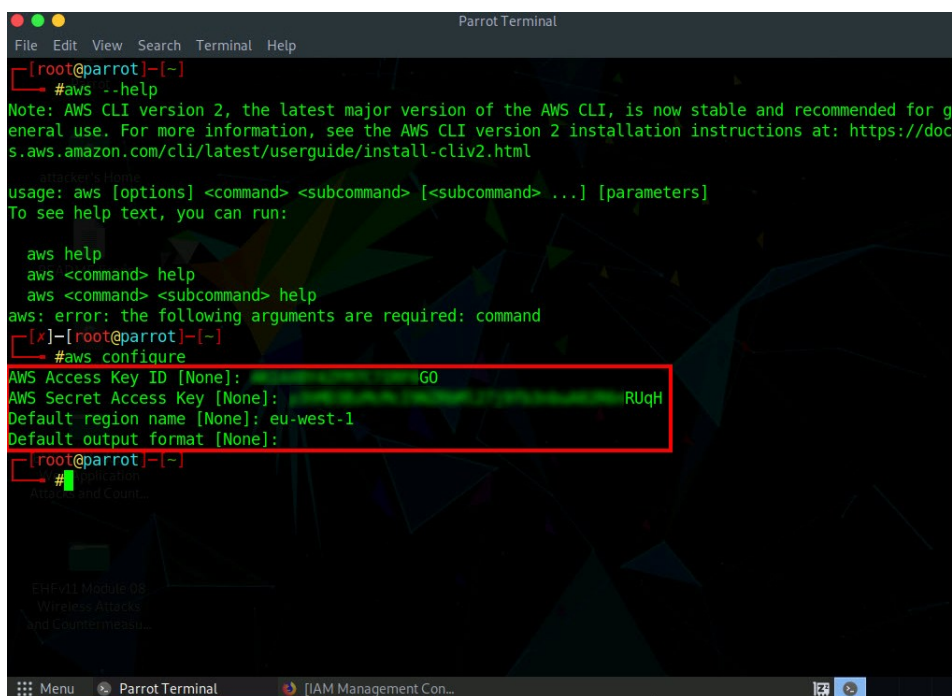
EXPECTED RESULT

The default region is set for the training session.

SECURITY INSIGHT

Region selection affects which regional S3 endpoint the CLI targets, so it must match where the training bucket resides.

LAB 2 | S3 BUCKET SECURITY ASSESSMENT



```
Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]~#
#aws --help
Note: AWS CLI version 2, the latest major version of the AWS CLI, is now stable and recommended for general use. For more information, see the AWS CLI version 2 installation instructions at: https://docs.aws.amazon.com/cli/latest/userguide/install-cliv2.html

usage: aws [options] <command> [<subcommand> [<subcommand> ...] [parameters]
To see help text, you can run:

    aws help
    aws <command> help
    aws <command> <subcommand> help
aws: error: the following arguments are required: command
[*]-[root@parrot]~#
#aws configure
AWS Access Key ID [None]: G0
AWS Secret Access Key [None]: RUqH
Default region name [None]: eu-west-1
Default output format [None]:
[root@parrot]~#
```

STEP 24 SET THE OUTPUT FORMAT**ACTION**

Leave the Default output format prompt at the instructor-defined setting and press Enter.

EXPECTED RESULT

AWS CLI configuration completes successfully.

SECURITY INSIGHT

Output format affects readability of CLI results but has no bearing on the security posture of the assessment.

STEP 25 IDENTIFY THE TRAINING BUCKET**ACTION**

For this lab, an intentionally open S3 bucket has been created for demonstration purposes as [INSTRUCTOR-ASSIGNED TRAINING BUCKET]. This bucket is used for the remainder of the exercise. Public buckets are typically found during the enumeration phase.

EXPECTED RESULT

The training bucket name is confirmed for use in the remaining steps.

SECURITY INSIGHT

Using a clearly designated training bucket ensures the exercise never touches real organizational data.

STEP 26 LIST BUCKET CONTENTS

ACTION

List the directories in the training bucket using `aws s3 ls s3://[Bucket Name]`, substituting the instructor-assigned training bucket name, then press Enter.

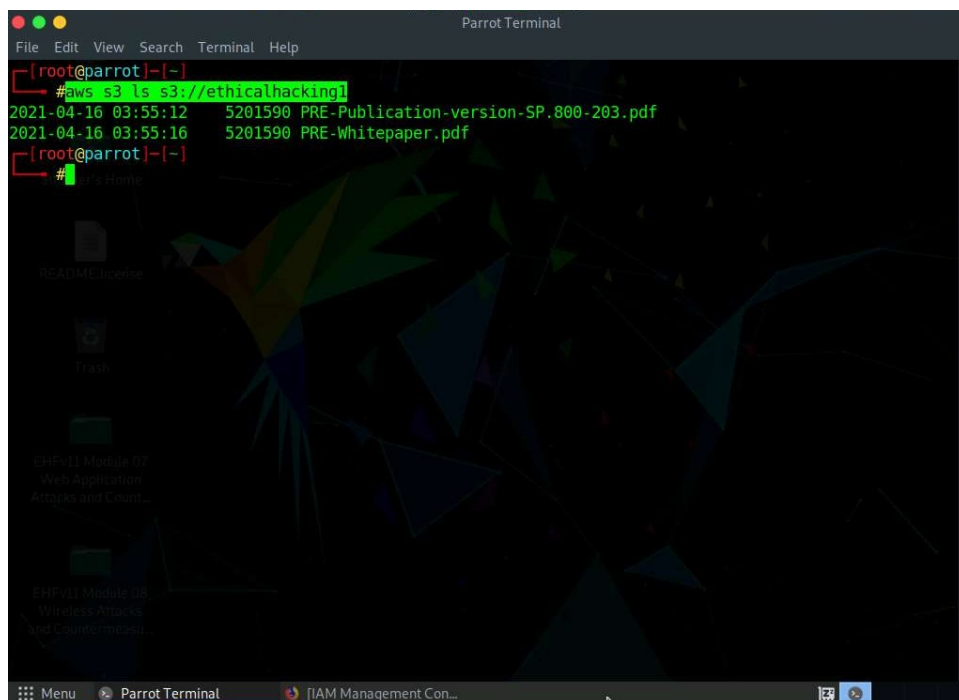
```
aws s3 ls s3://[INSTRUCTOR-ASSIGNED TRAINING BUCKET]
```

EXPECTED RESULT

The list of directories or objects in the training bucket is displayed.

SECURITY INSIGHT

Object listing is the first indicator of how much a misconfigured bucket reveals to an unauthenticated or under-restricted caller.



STEP 27 REVIEW THE OBJECT LISTING**ACTION**

Review the object listing returned from the authorized training bucket. Document only non-sensitive training information.

EXPECTED RESULT

The training bucket's directory and object structure is reviewed.

SECURITY INSIGHT

Even bucket and object naming conventions can leak information about an organization's internal structure.

STEP 28 REVIEW THE BUCKET ENDPOINT IN THE BROWSER**ACTION**

Open the approved browser and review the instructor-provided training bucket endpoint if the exercise requires browser-based verification.

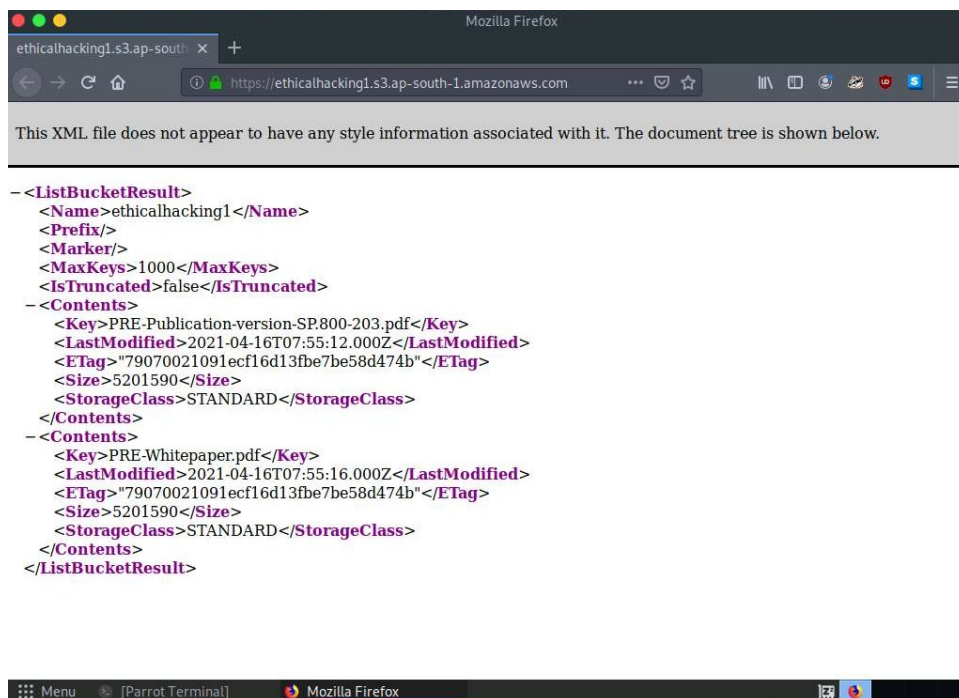
EXPECTED RESULT

The training bucket's public endpoint is reachable in the browser.

SECURITY INSIGHT

Confirming access through both the CLI and a browser demonstrates that the exposure is not limited to a single access path.

LAB 2 | S3 BUCKET SECURITY ASSESSMENT



```
-<ListBucketResult>
  <Name>ethicalhacking1</Name>
  <Prefix/>
  <Marker/>
  <MaxKeys>1000</MaxKeys>
  <IsTruncated>false</IsTruncated>
  -<Contents>
    <Key>PRE-Publication-version-SP800-203.pdf</Key>
    <LastModified>2021-04-16T07:55:12.000Z</LastModified>
    <ETag>"79070021091ecf16d13fbe7be58d474b"</ETag>
    <Size>5201590</Size>
    <StorageClass>STANDARD</StorageClass>
  </Contents>
  -<Contents>
    <Key>PRE-Whitepaper.pdf</Key>
    <LastModified>2021-04-16T07:55:16.000Z</LastModified>
    <ETag>"79070021091ecf16d13fbe7be58d474b"</ETag>
    <Size>5201590</Size>
    <StorageClass>STANDARD</StorageClass>
  </Contents>
</ListBucketResult>
```

STEP 29 REVIEW AVAILABLE OBJECTS AND PERMISSIONS**ACTION**

Review the available training objects and permissions as displayed by the browser.

EXPECTED RESULT

The full list of directories and files available in the training bucket is visible.

SECURITY INSIGHT

Cross-checking CLI and browser results helps confirm the scope of the exposure consistently.

STEP 30 RETURN TO THE TERMINAL**ACTION**

Minimize the browser window and switch back to the Terminal window.

EXPECTED RESULT

The terminal is active and ready for the next command.

SECURITY INSIGHT

Switching context deliberately between browser and terminal keeps the assessment steps organized and easy to document.

STEP 31 CREATE A HARMLESS TRAINING FILE

ACTION

Create a harmless sample file for the training exercise, for example: echo "Internshield S3 Security Training Object" > Training.txt, then press Enter.

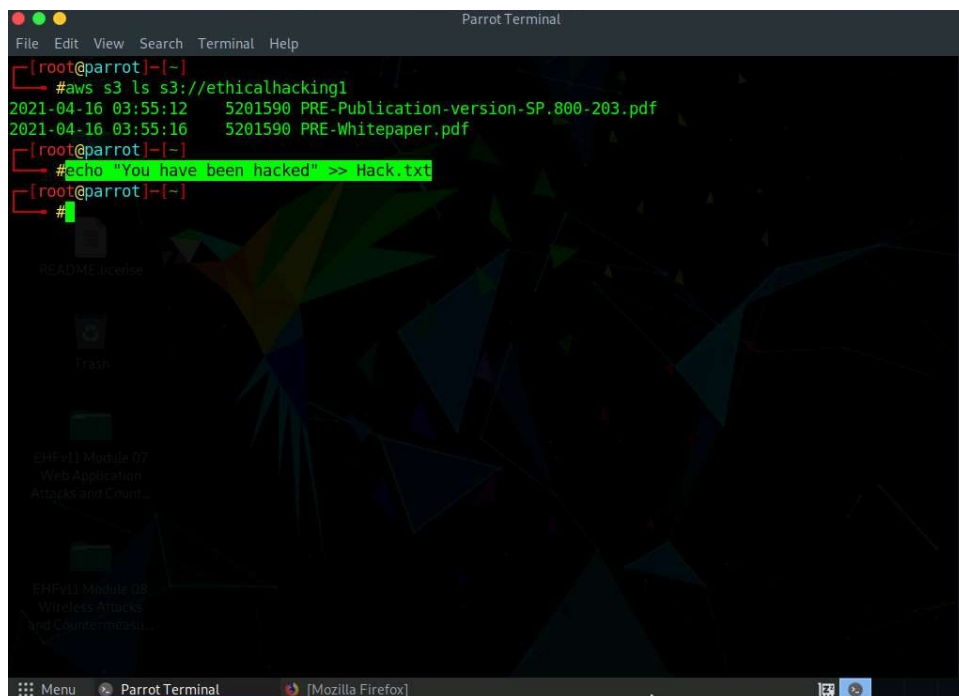
```
echo "Internshield S3 Security Training Object" > Training.txt  
# Vidit Shringi
```

EXPECTED RESULT

A local file named Training.txt is created.

SECURITY INSIGHT

Using an explicitly harmless, clearly labeled training file avoids any resemblance to malicious payload staging.



STEP 32 CONFIRM THE TRAINING FILE PURPOSE

ACTION

This command creates a local sample file that will be used to demonstrate excessive write permission on the training bucket.

EXPECTED RESULT

The training file exists locally and is ready to be uploaded.

SECURITY INSIGHT

Demonstrating write-permission impact only requires a benign marker file, never executable or malicious content.

STEP 33 UPLOAD THE TRAINING FILE**ACTION**

Upload the harmless training file to the instructor-provided training bucket using `aws s3 mv Training.txt s3://[INSTRUCTOR-ASSIGNED TRAINING BUCKET]` and press Enter.

```
aws s3 mv Training.txt s3://[INSTRUCTOR-ASSIGNED TRAINING BUCKET]
```

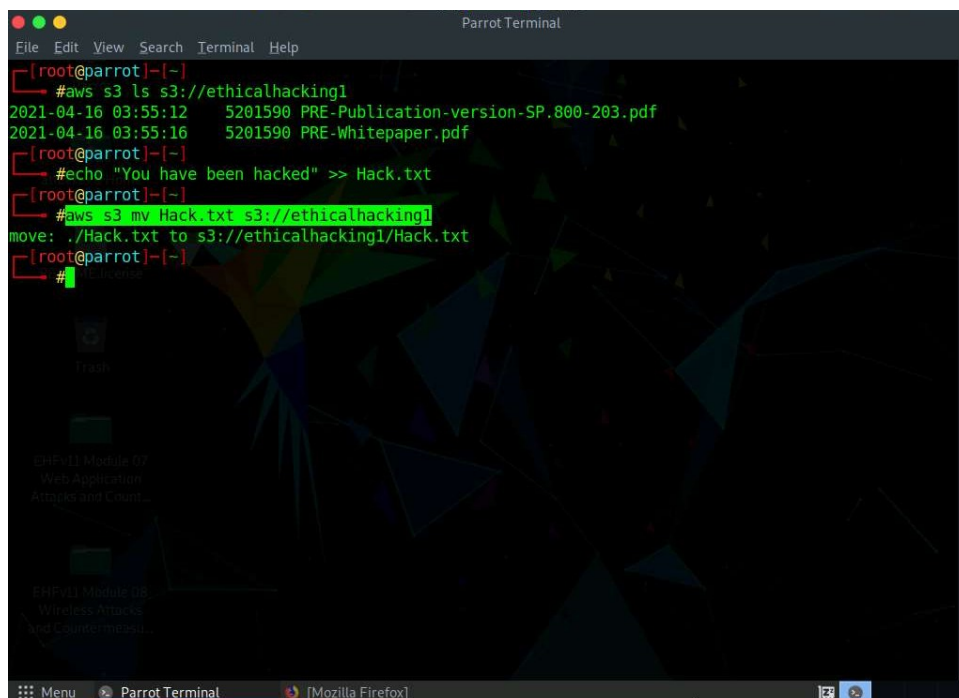
EXPECTED RESULT

The training file is moved to the training bucket.

SECURITY INSIGHT

Successful upload demonstrates that the bucket's permissions allow write access beyond what is typically appropriate.

LAB 2 | S3 BUCKET SECURITY ASSESSMENT



```
[root@parrot]~#  
[root@parrot]~# aws s3 ls s3://ethicalhacking1  
2021-04-16 03:55:12    5201590 PRE-Publication-version-SP.800-203.pdf  
2021-04-16 03:55:16    5201590 PRE-Whitepaper.pdf  
[root@parrot]~#  
[root@parrot]~# echo "You have been hacked" >> Hack.txt  
[root@parrot]~#  
[root@parrot]~# aws s3 mv Hack.txt s3://ethicalhacking1  
move: ./Hack.txt to s3://ethicalhacking1/Hack.txt  
[root@parrot]~#  
[root@parrot]~#
```

STEP 34 CONFIRM UPLOAD SUCCESS**ACTION**

Confirm that the training object was uploaded successfully based on the terminal output.

EXPECTED RESULT

The CLI output confirms the object was moved to the bucket.

SECURITY INSIGHT

Confirming each action's outcome before moving on keeps the assessment trail accurate for later documentation.

STEP 35 RETURN TO THE BROWSER OR CONSOLE**ACTION**

Return to the browser or AWS console to verify the upload visually.

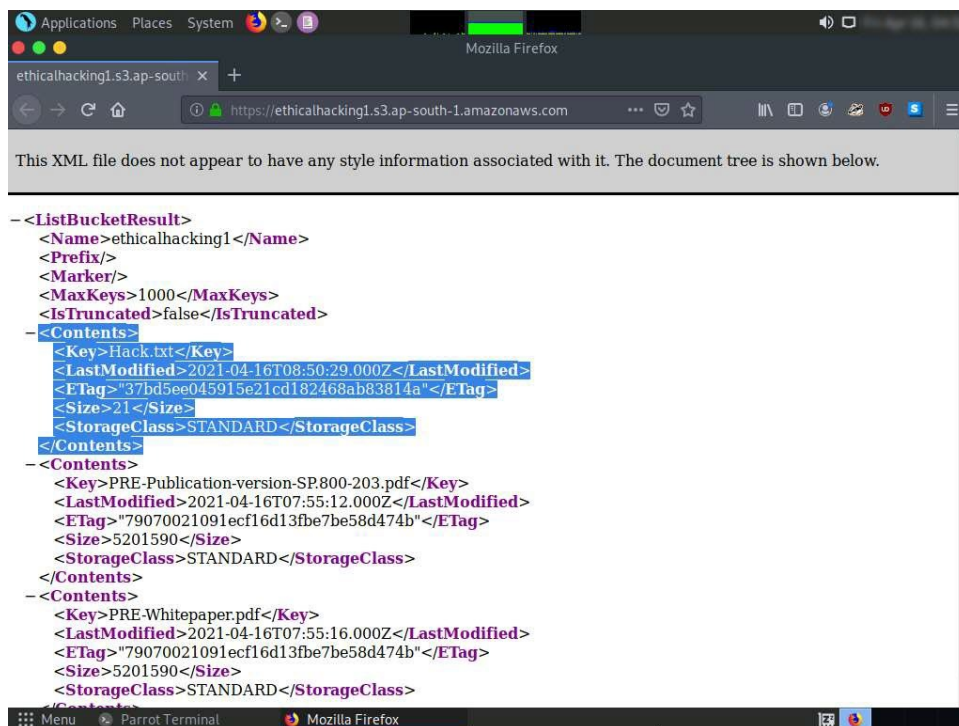
EXPECTED RESULT

The browser is ready to reload the training bucket view.

SECURITY INSIGHT

LAB 2 | S3 BUCKET SECURITY ASSESSMENT

Independent verification through a second access path strengthens confidence in the observed finding.



```
-<ListBucketResult>
  <Name>ethicalhacking1</Name>
  <Prefix/>
  <Marker/>
  <MaxKeys>1000</MaxKeys>
  <IsTruncated>false</IsTruncated>
  <Contents>
    <Key>Hack.txt</Key>
    <LastModified>2021-04-16T08:50:29.000Z</LastModified>
    <ETag>"37bd5ee045915e21cd182468ab83814a"</ETag>
    <Size>21</Size>
    <StorageClass>STANDARD</StorageClass>
  </Contents>
  <Contents>
    <Key>PRE-Publication-version-SP800-203.pdf</Key>
    <LastModified>2021-04-16T07:55:12.000Z</LastModified>
    <ETag>"79070021091ecf16d13fbe7be58d474b"</ETag>
    <Size>5201590</Size>
    <StorageClass>STANDARD</StorageClass>
  </Contents>
  <Contents>
    <Key>PRE-Whitepaper.pdf</Key>
    <LastModified>2021-04-16T07:55:16.000Z</LastModified>
    <ETag>"79070021091ecf16d13fbe7be58d474b"</ETag>
    <Size>5201590</Size>
    <StorageClass>STANDARD</StorageClass>
  </Contents>
```

STEP 36 VERIFY THE UPLOADED OBJECT**ACTION**

Refresh the training bucket view and verify that the harmless training object is visible.

EXPECTED RESULT

The Training.txt object appears in the training bucket listing.

SECURITY INSIGHT

Visual confirmation in the browser corroborates the CLI-reported upload success.

STEP 37 RETURN TO THE TERMINAL**ACTION**

Minimize the browser window and switch back to the Terminal window.

EXPECTED RESULT

The terminal is active and ready for the next command.

SECURITY INSIGHT

Consistent context switching keeps the procedure easy to follow and document.

STEP 38 REMOVE THE TRAINING OBJECT

ACTION

Remove the harmless training object from the training bucket using `aws s3 rm s3://[INSTRUCTOR-ASSIGNED TRAINING BUCKET]/Training.txt` and press Enter.

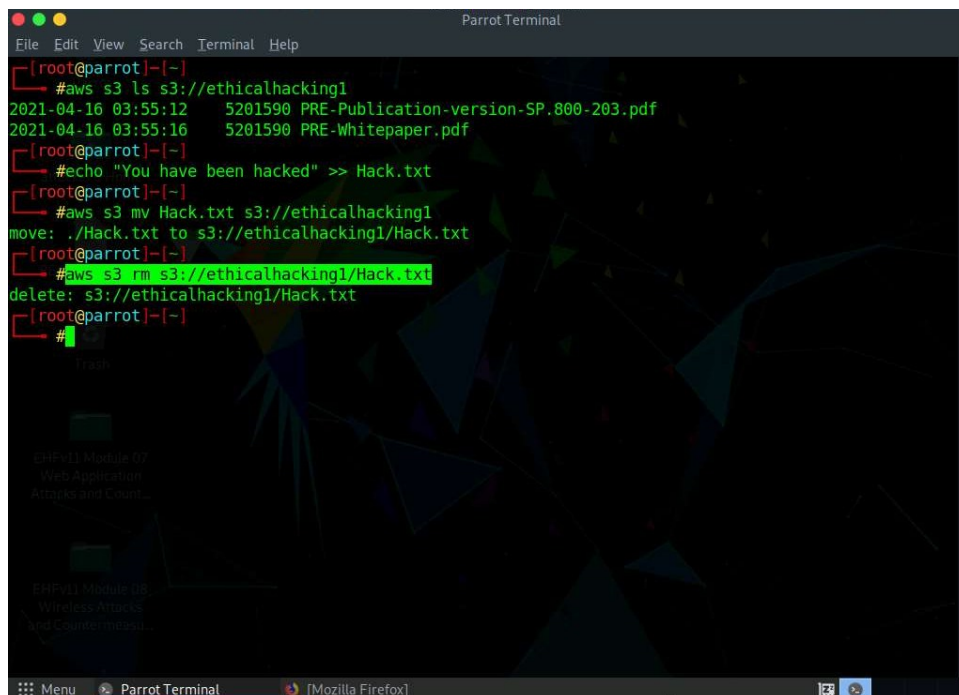
```
aws s3 rm s3://[INSTRUCTOR-ASSIGNED TRAINING BUCKET]/Training.txt
```

EXPECTED RESULT

The training object is removed from the bucket.

SECURITY INSIGHT

Successful deletion demonstrates that the bucket's permissions also allow unauthorized delete access.



```
Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]~#
[root@parrot]~# #aws s3 ls s3://ethicalhacking1
2021-04-16 03:55:12      5201590 PRE-Publication-version-SP.800-203.pdf
2021-04-16 03:55:16      5201590 PRE-Whitepaper.pdf
[root@parrot]~#
[root@parrot]~# #echo "You have been hacked" >> Hack.txt
[root@parrot]~#
[root@parrot]~# #aws s3 mv Hack.txt s3://ethicalhacking1
move: ./Hack.txt to s3://ethicalhacking1/Hack.txt
[root@parrot]~#
[root@parrot]~# #aws s3 rm s3://ethicalhacking1/Hack.txt
delete: s3://ethicalhacking1/Hack.txt
[root@parrot]~#
#
```

STEP 39 CONFIRM REMOVAL SUCCESS**ACTION**

Confirm that the training object was removed successfully based on the terminal output.

EXPECTED RESULT

The CLI output confirms the object was deleted.

SECURITY INSIGHT

Confirming deletion output is important since delete operations are irreversible without versioning enabled.

STEP 40 RETURN TO THE BROWSER OR CONSOLE**ACTION**

Return to the approved browser or AWS console to verify the removal visually.

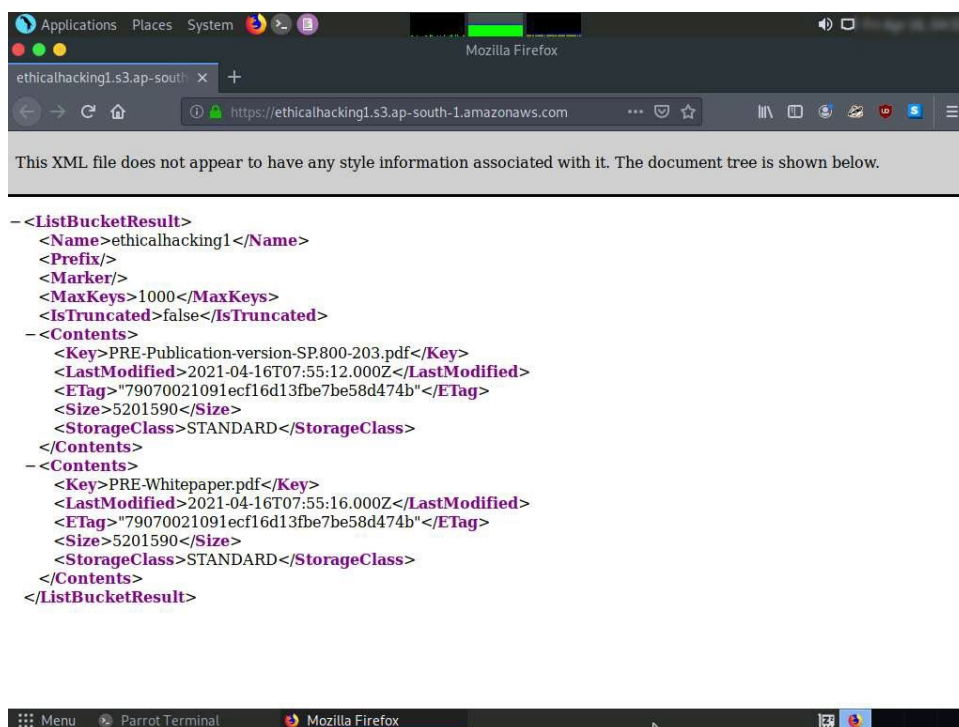
EXPECTED RESULT

The browser is ready to reload the training bucket view.

SECURITY INSIGHT

A second verification pass ensures the finding is consistent across access methods.

LAB 2 | S3 BUCKET SECURITY ASSESSMENT



```
-<ListBucketResult>
  <Name>ethicalhacking1</Name>
  <Prefix/>
  <Marker/>
  <MaxKeys>1000</MaxKeys>
  <IsTruncated>false</IsTruncated>
  -<Contents>
    <Key>PRE-Publication-version-SP.800-203.pdf</Key>
    <LastModified>2021-04-16T07:55:12.000Z</LastModified>
    <ETag>"79070021091ecf16d13fbe7be58d474b"</ETag>
    <Size>5201590</Size>
    <StorageClass>STANDARD</StorageClass>
  </Contents>
  -<Contents>
    <Key>PRE-Whitepaper.pdf</Key>
    <LastModified>2021-04-16T07:55:16.000Z</LastModified>
    <ETag>"79070021091ecf16d13fbe7be58d474b"</ETag>
    <Size>5201590</Size>
    <StorageClass>STANDARD</StorageClass>
  </Contents>
</ListBucketResult>
```

STEP 41 VERIFY THE OBJECT WAS REMOVED**ACTION**

Refresh the training bucket view and verify that the training object is no longer present.

EXPECTED RESULT

The Training.txt object is no longer listed in the training bucket.

SECURITY INSIGHT

Confirming removal closes the loop on demonstrating both excessive write and excessive delete permissions.

STEP 42 EXPLAIN THE SECURITY FINDING**ACTION**

Explain the security finding: excessive S3 permissions may allow unauthorized users to list, upload, modify, or delete objects.

EXPECTED RESULT

The security implication of the observed permissions is clearly articulated.

SECURITY INSIGHT

Translating a technical observation into a plain-language risk statement is a core skill for security reporting.

STEP 43 CONCLUDE THE DEMONSTRATION**ACTION**

Conclude the controlled demonstration of excessive permissions on an intentionally misconfigured S3 training bucket.

EXPECTED RESULT

The practical demonstration is complete.

SECURITY INSIGHT

Formally closing the technical activity supports a clean transition into analysis and reporting.

STEP 44 CLOSE APPLICATIONS AND DOCUMENT FINDINGS**ACTION**

Close the required applications and document the observations, security impact, and recommended countermeasures.

EXPECTED RESULT

All findings, impact, and recommended countermeasures are documented.

SECURITY INSIGHT

Thorough documentation is what turns a hands-on exercise into an actionable security assessment report.

SECURITY ANALYSIS

Excessive S3 permissions create risk across all three pillars of information security:

Confidentiality

Unauthorized access to stored objects can expose sensitive files to parties who were never intended to view them.

Integrity

Unauthorized modification or upload of objects can alter application data, configuration files, or code without detection.

Availability

Unauthorized deletion of objects can remove data that legitimate users or systems depend on.

- Public bucket exposure
- Excessive permissions
- Weak bucket policies
- Insecure ACL configuration
- Credential compromise
- Unauthorized object operations

S3 ACCESS-CONTROL MODEL

IDENTITY
AUTHENTICATION
AUTHORIZATION
BUCKET POLICY / IAM / ACL
S3 OBJECT
READ / WRITE / DELETE

S3 SECURITY COUNTERMEASURES

- Block unnecessary public access.
- Apply least privilege.
- Review IAM permissions.
- Review bucket policies.
- Review ACL configuration.
- Use temporary credentials.
- Avoid long-lived access keys.
- Enable MFA where appropriate.
- Enable logging and monitoring.
- Monitor unusual object operations.
- Protect sensitive objects.
- Use encryption where appropriate.
- Remove unused buckets and objects.
- Regularly review permissions.

LEARNING OUTCOMES

After completing this lab, students should be able to:

- 1. Explain S3 bucket security.
- 2. Explain excessive S3 permissions.
- 3. Use AWS CLI in an authorized training environment.
- 4. List objects in a designated training bucket.
- 5. Demonstrate controlled object upload in the sandbox.
- 6. Demonstrate controlled object deletion in the sandbox.
- 7. Analyze confidentiality, integrity, and availability impact.
- 8. Identify S3 security misconfigurations.
- 9. Recommend appropriate countermeasures.
- 10. Handle cloud credentials securely.

LAB OBSERVATION

Activity	Observation	Security Significance
AWS CLI Setup		
Credential Configuration		
Training Bucket Access		
Object Listing		
Object Upload		
Object Verification		
Object Removal		
Object Removal Verification		
Security Finding		
Countermeasure		

SECURITY FINDING

Finding	Risk	Impact	Countermeasure
Excessive Write Permission	High	Unauthorized Object Modification	Restrict Write Access
Excessive Delete Permission	High	Data Availability Impact	Restrict Delete Permission
Public Access	High	Unauthorized Data Exposure	Block Public Access

Risk ratings above reflect the demonstrated training configuration and should not be assumed to apply automatically to other environments.

LAB COMPLETION CHECKLIST

- ☐ Authorized training environment confirmed
- ☐ Temporary credentials used
- ☐ No production credentials used
- ☐ AWS CLI available
- ☐ Training bucket identified
- ☐ Object listing reviewed
- ☐ Harmless training object created
- ☐ Controlled upload completed
- ☐ Upload verified
- ☐ Controlled removal completed
- ☐ Removal verified
- ☐ Security impact documented
- ☐ Countermeasures documented
- ☐ Credentials removed/disabled as instructed
- ☐ Training resources restored



REVIEW QUESTIONS

- 1. What is Amazon S3?
- 2. What is the AWS CLI?
- 3. What are excessive S3 permissions?
- 4. How can excessive read permission affect confidentiality?
- 5. How can excessive write permission affect integrity?
- 6. How can excessive delete permission affect availability?
- 7. Why should long-lived access keys be avoided?
- 8. What is the purpose of least privilege?
- 9. What controls can prevent public S3 exposure?
- 10. Why must this assessment be restricted to authorized training resources?

TROUBLESHOOTING

Problem	Possible Cause	Recommended Action
AWS CLI unavailable	Installation not completed or Python/pip missing	Re-run the installation step and confirm pip3 is available
AWS CLI configuration failure	Incorrect input at a configuration prompt	Re-run aws configure and re-enter each field carefully
Authentication failure	Invalid or expired temporary credentials	Obtain fresh temporary credentials from the instructor-provided mechanism
Incorrect training region	Region does not match the training bucket's region	Set the default region to the instructor-assigned training region
Training bucket unavailable	Bucket not yet provisioned or lab setup incomplete	Confirm with the instructor that the training bucket has been created
Permission denied	Credentials lack the permissions used in this exercise	Confirm the correct training credentials are configured
Object upload fails	Incorrect bucket name or insufficient write permission	Verify the bucket name and confirm write permission is enabled for the exercise
Object removal fails	Incorrect object path or insufficient delete permission	Verify the object path and confirm delete permission is enabled for the exercise
Browser verification differs from CLI output	Caching or delayed propagation	Reload the page and allow a short delay before re-checking

BEST PRACTICES

- Use temporary training credentials.
- Never expose secret access keys.
- Never commit credentials to GitHub or any repository.
- Never use root credentials for routine tasks.
- Use dedicated training buckets.
- Never target third-party buckets.
- Use harmless sample files.
- Do not upload malware or exploit payloads.
- Verify permissions before testing.
- Remove training resources after the lab.
- Document findings professionally.
- Apply least privilege.

LAB SUMMARY

This laboratory demonstrated how excessive S3 permissions can create security risks involving object listing, upload, modification, and deletion, using controlled actions against an authorized training bucket.

DISCOVER
ASSESS
VALIDATE
ANALYZE
REMEDIATE
VERIFY